

Hacking with Artificial Intelligence

Exploring Web Hacking with Reinforcement Learning

Songhyun Bae (Otwooo)

© Hackingcamp. All Rights Reserved



Who Am I

Songhyun Bae (Otwooo)

Senior at Daejeon Daeshin High School



Web Hacking, Reverse Engineering, Algorithms, AI

otwooo.github.io/about

© Hackingcamp. All Rights Reserved

Presentation Overview

An AI-Based Security Project

- AI Fundamentals
- Applying AI to Hacking

© Hackingcamp. All Rights Reserved

AI Today

OpenAI

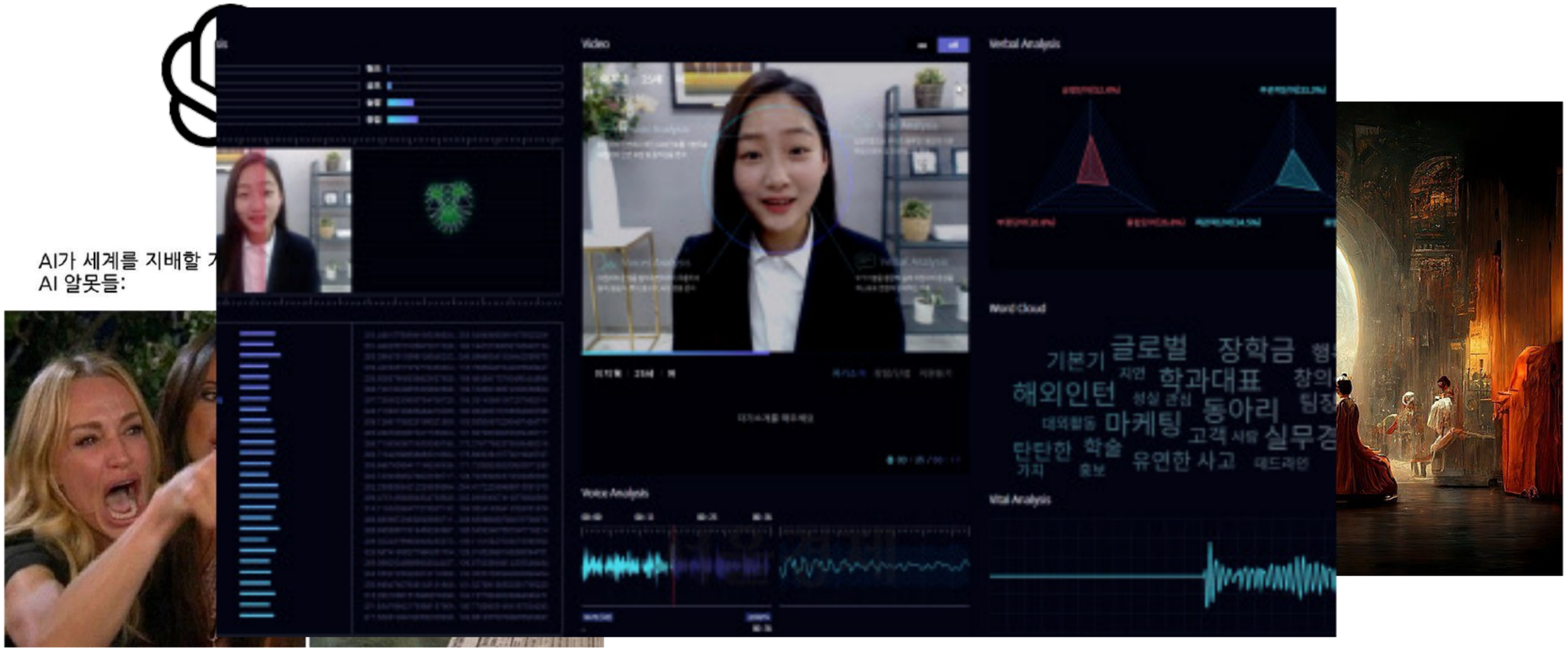




© Hackingcamp. All Rights Reserved

POC SECURITY

AI Today



© Hackingcamp. All Rights Reserved

POC SECURITY

AI Today



© Hackingcamp. All Rights Reserved

POC SECURITY

Vulnerability Assessment

Attack Target



OWASP
Open Web Application Security Project

Vulnerability

© Hackingcamp. All Rights Reserved

POC SECURITY

Could AI Do This?

Attack Target



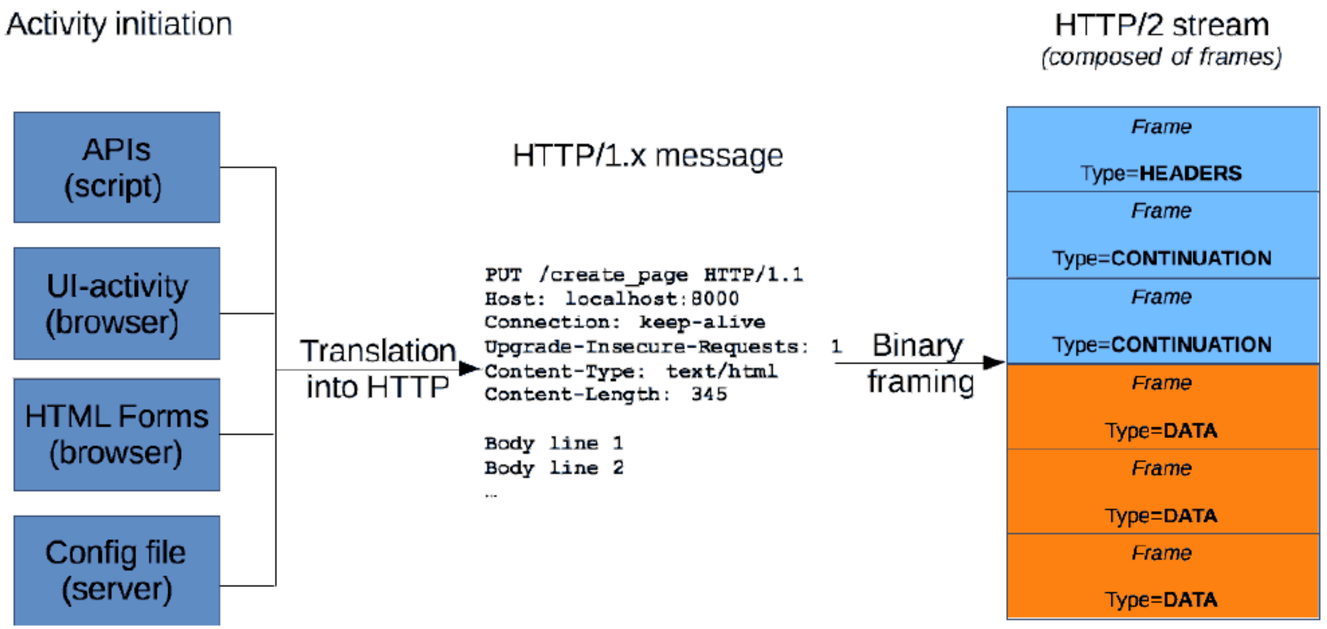
Open Web Application Security Project

Vulnerability

© Hackingcamp. All Rights Reserved

POC SECURITY

AI in Security



Attack Detection

Attack Classification

© Hackingcamp. All Rights Reserved

POC SECURITY

AI in Security



AI-Based Malware Analysis

© Hackingcamp. All Rights Reserved

POC SECURITY

AI in Security

```
}
dword_4BEC7C = fopen(&FileName, "wb");
if ( dword_4BEC7C )
{
  sub_401F10(lpString2, 0);
  fclose(dword_4BEC7C);
  String1 = 0;
  v10 = 0;
  v11 = 0;
  v12 = 0;
  v4 = strrchr(a2, 92);
  lstrcpyA(&String1, v4 + 1);
  v5 = strrchr(&String1, 46);
```



Vulnerable Function Detection

© Hackingcamp. All Rights Reserved

POC SECURITY

The Biggest Challenge

High-quality data is hard to obtain.

That leaves mostly classification and detection.

© Hackingcamp. All Rights Reserved

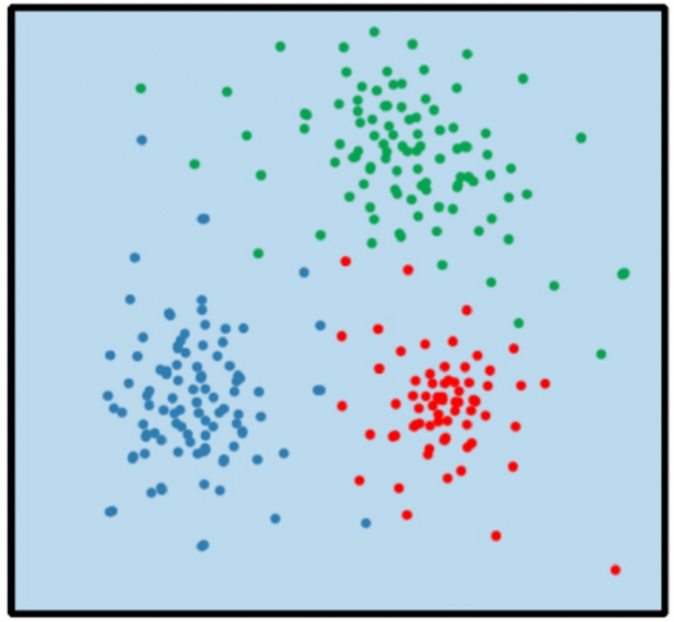
What I Want to Build

Can AI act like a human
and find vulnerabilities?

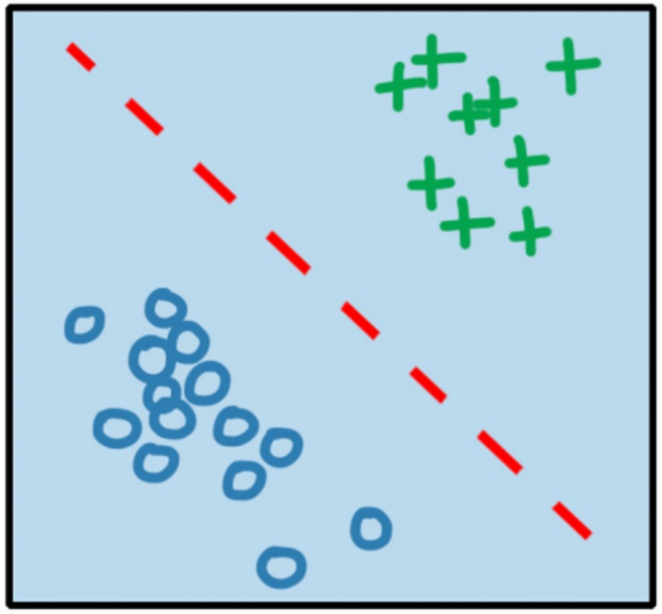
© Hackingcamp. All Rights Reserved

Artificial Intelligence

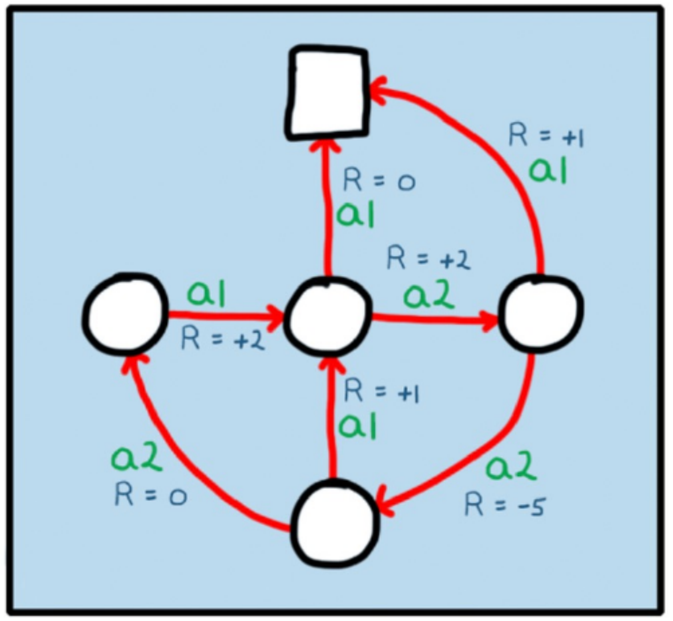
Supervised Learning



Unsupervised Learning



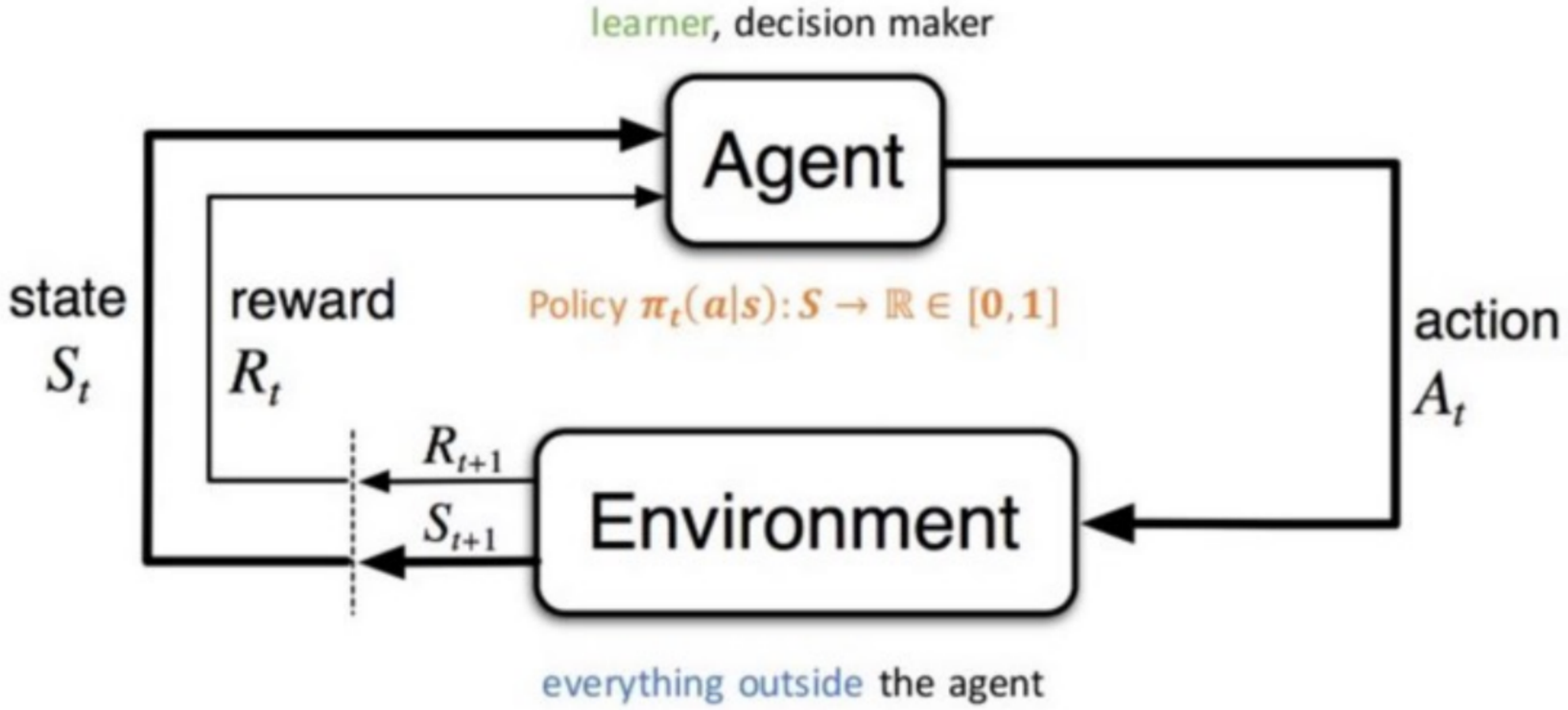
Reinforcement Learning



© Hackingcamp. All Rights Reserved

POC SECURITY

Reinforcement Learning



© Hackingcamp. All Rights Reserved

POC SECURITY

Environment



0: Move left

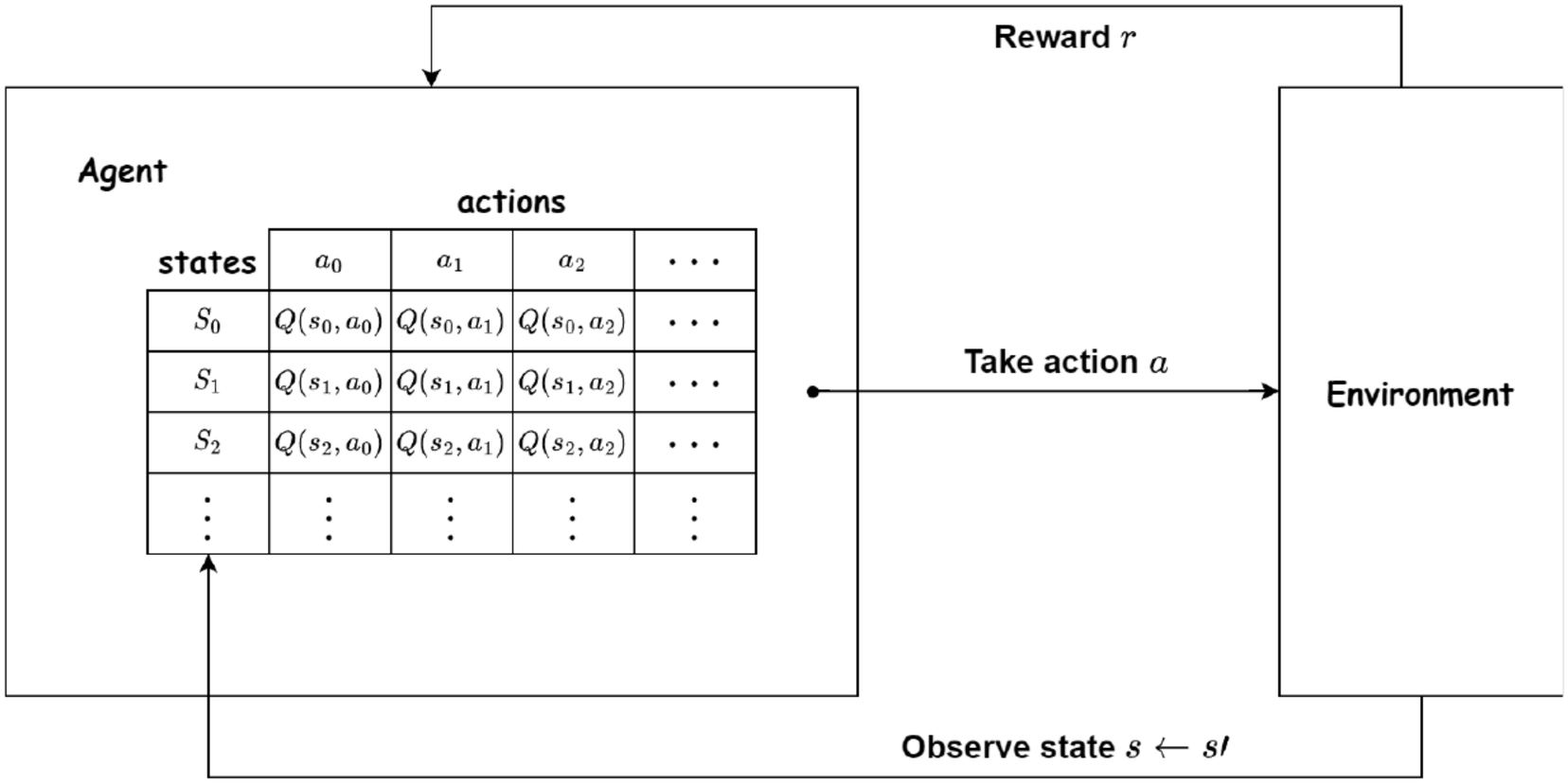
1: Move down

2: Move right

3: Move up

© Hackingcamp. All Rights Reserved

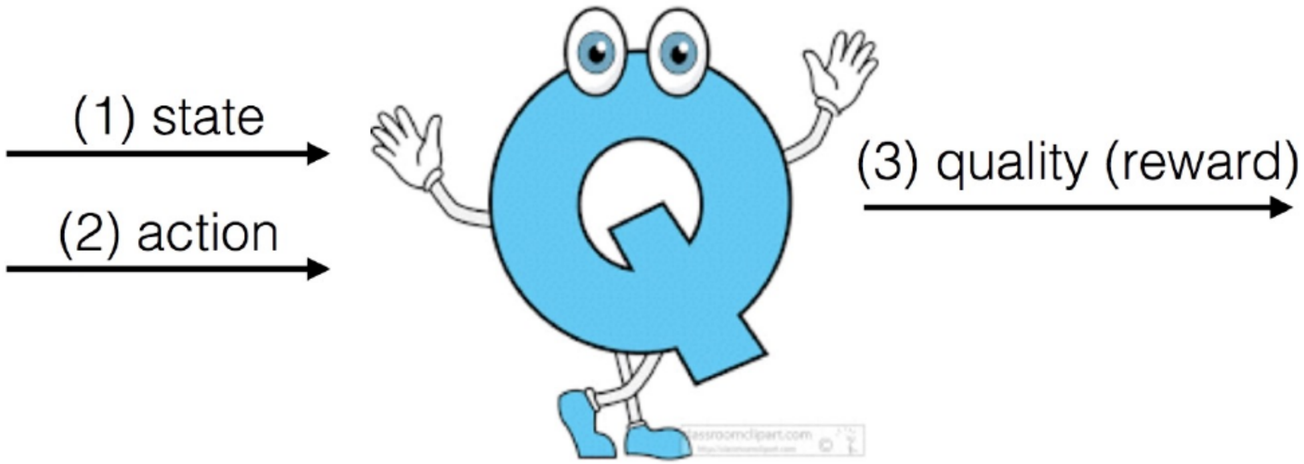
Q-Learning



© Hackingcamp. All Rights Reserved

POC SECURITY

Q-Learning



Q(state, action)

-> Q value

© Hackingcamp. All Rights Reserved

Q-Learning

s	1	2	3
4	5	6	7
8	9	10	11
12	13	14	15

State

Q(3, Right) = 0

Q(3, Left) = 0.1

Q(3, Up) = 0

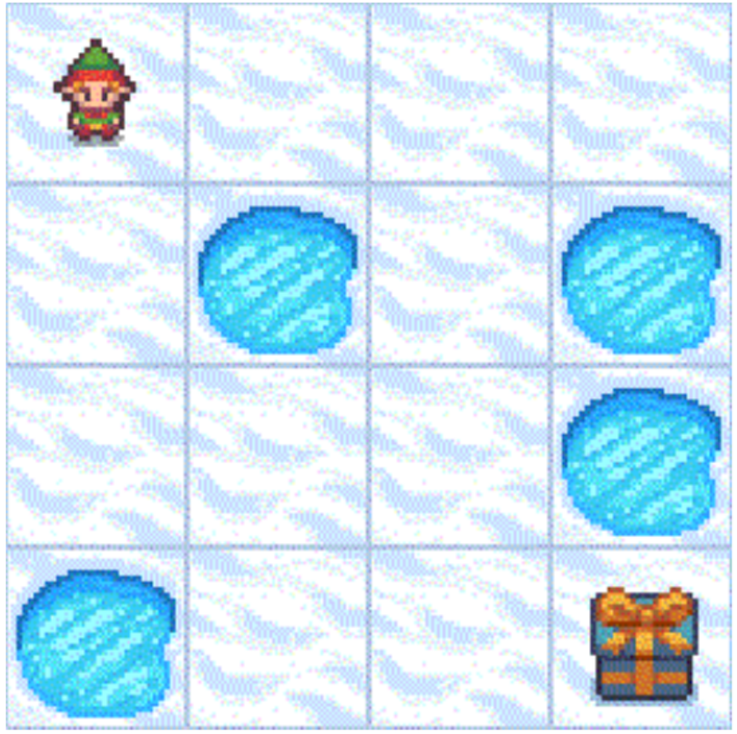
Q(3, Down) = 0.8

© Hackingcamp. All Rights Reserved

Q-Learning

	↑	↓	←	→
state1	-5	0	-5	0
state2	-5	15	0	-5
state3	0	-5	-5	15

Q-Table



© Hackingcamp. All Rights Reserved

Q-Learning

How do we assign Q values?

To account for future rewards, add the maximum expected reward from the current state through the end.

$$R_t = r_t + r_{t+1} + r_{t+2} + \cdots + r_n$$

© Hackingcamp. All Rights Reserved

Q-Learning

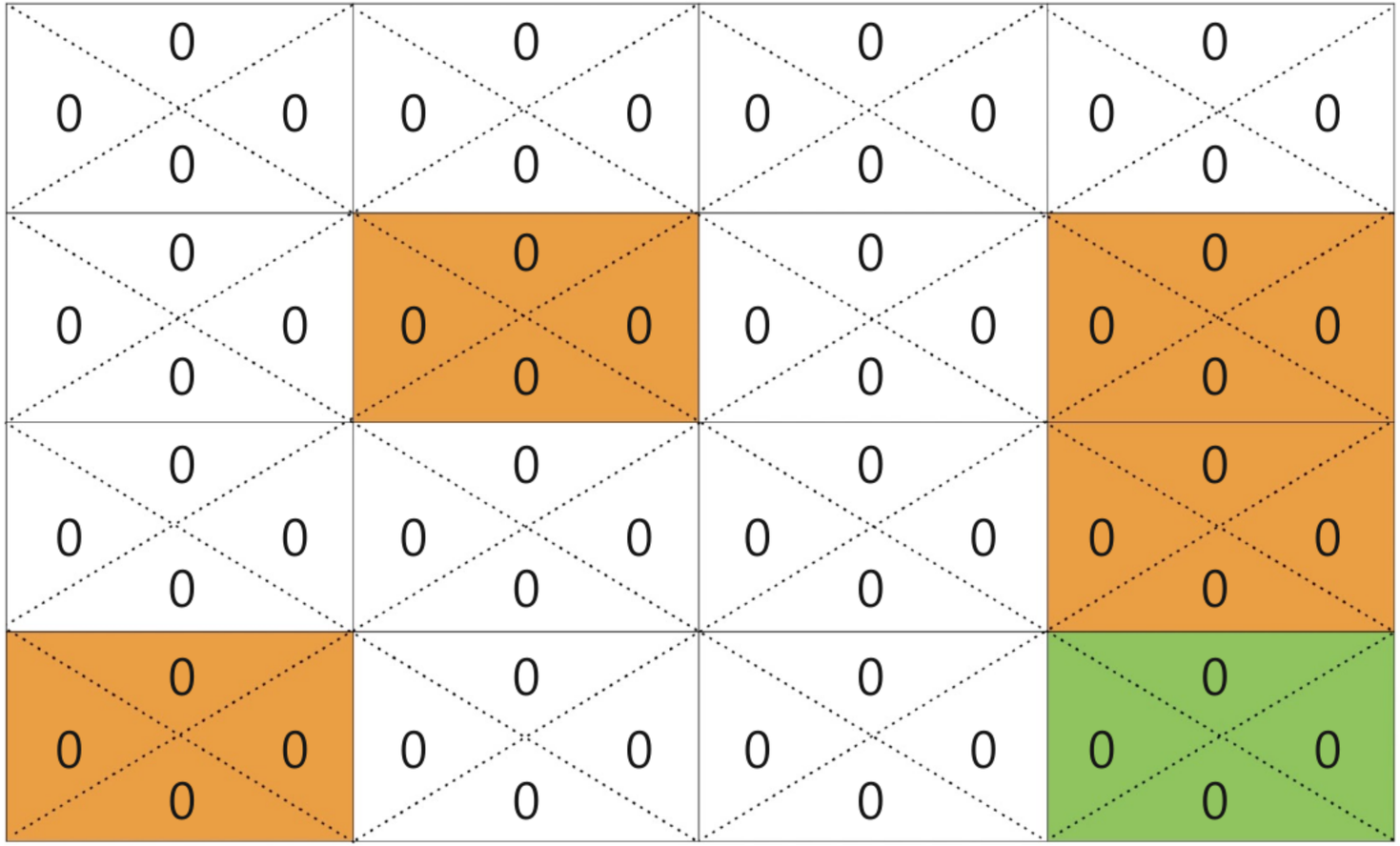
γ **The discount factor weights current rewards above future rewards.**

$$R_t = \gamma\, r_t + \gamma^2\, r_{t+1} + \gamma^3\, r_{t+2} + \cdots + \gamma^n\, r_n$$

$$Q(s,a) = r + \gamma \max_{a\prime} Q(s',a')$$

© Hackingcamp. All Rights Reserved

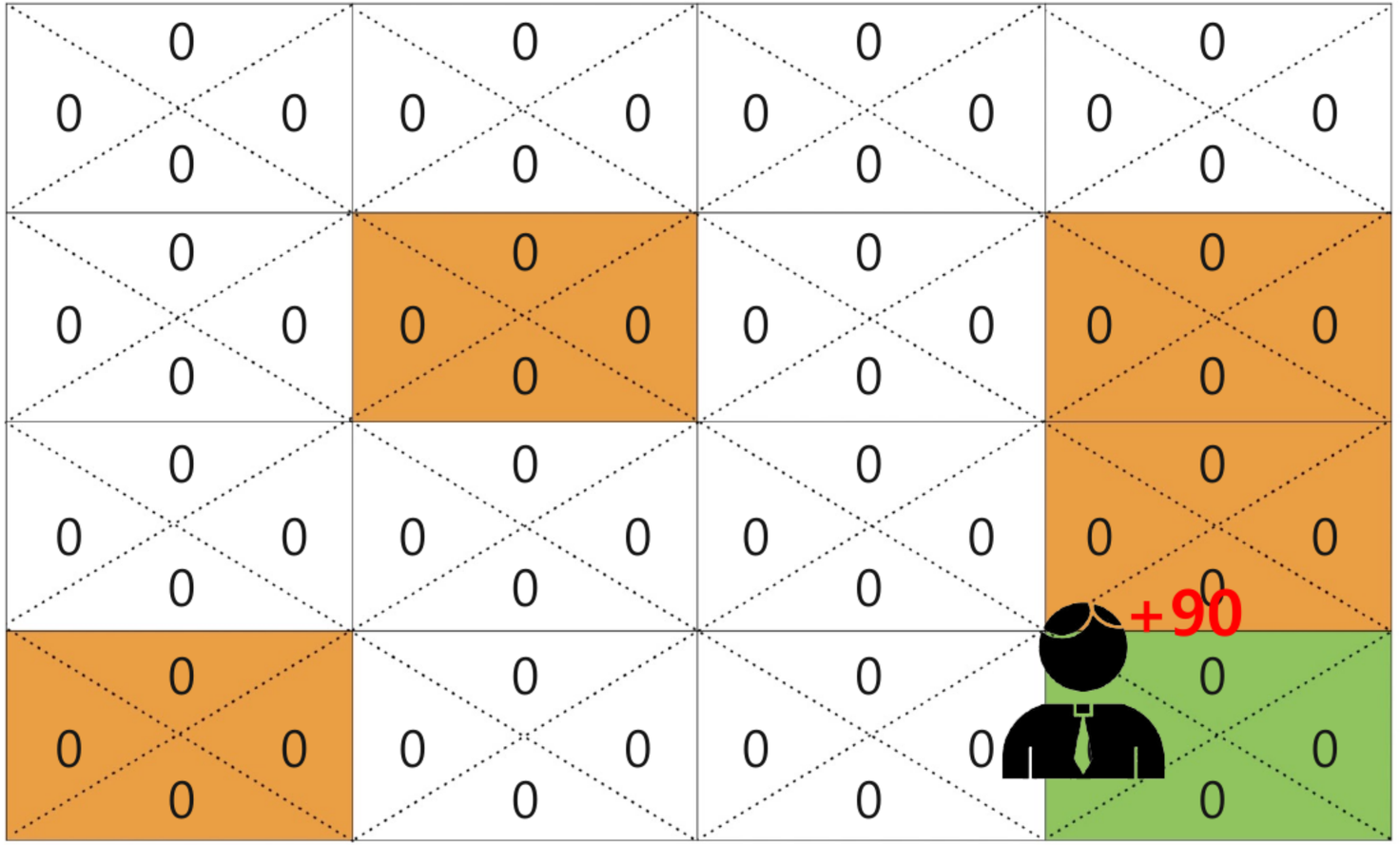
Q-Learning



© Hackingcamp. All Rights Reserved

POC SECURITY

Q-Learning



γ(disc.) = 0.9

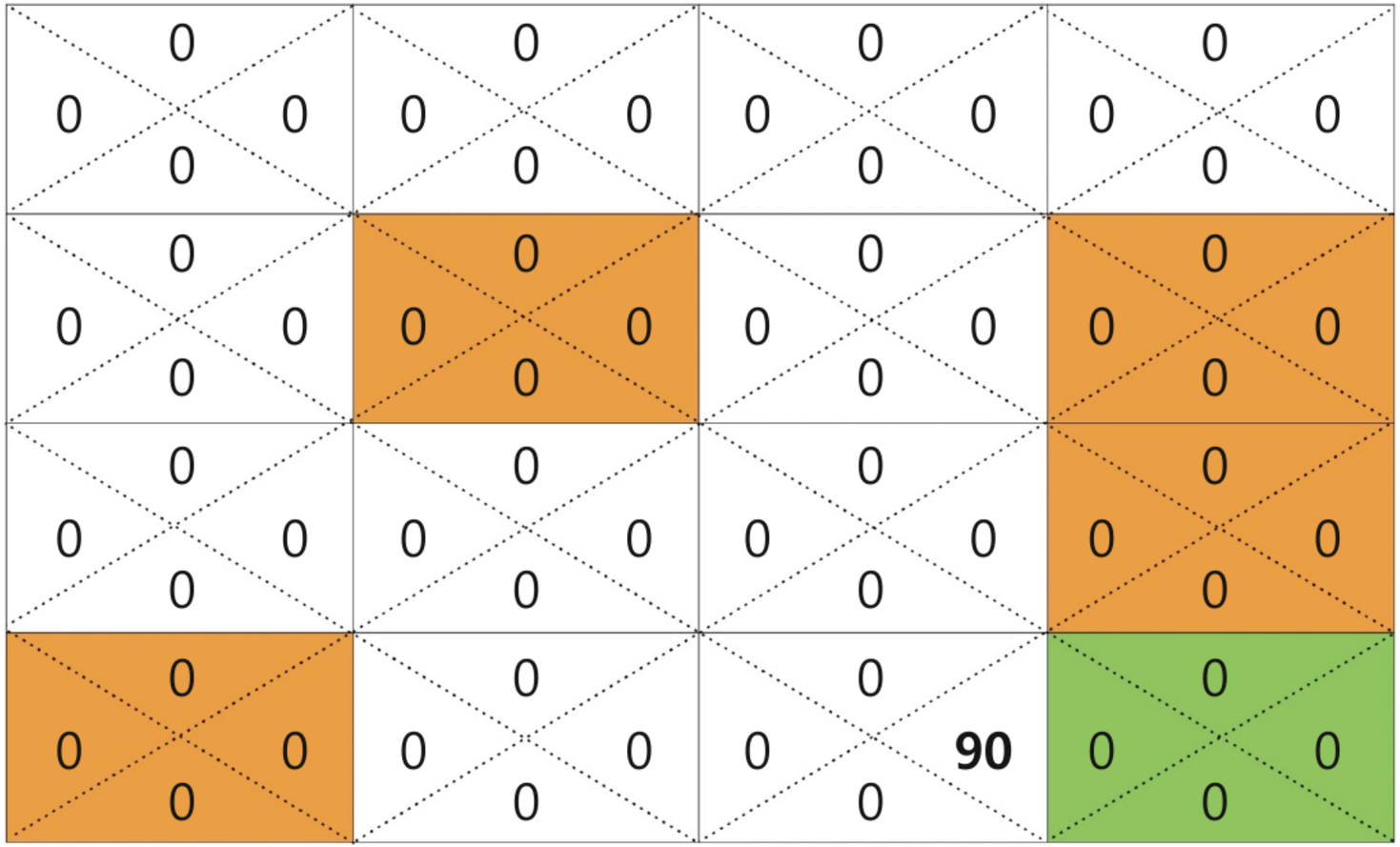
Q(14, Right)
= r + γ max(Q(s_{15}, a))

Q(14, Right)
= 90 + 0.9*0
= 90

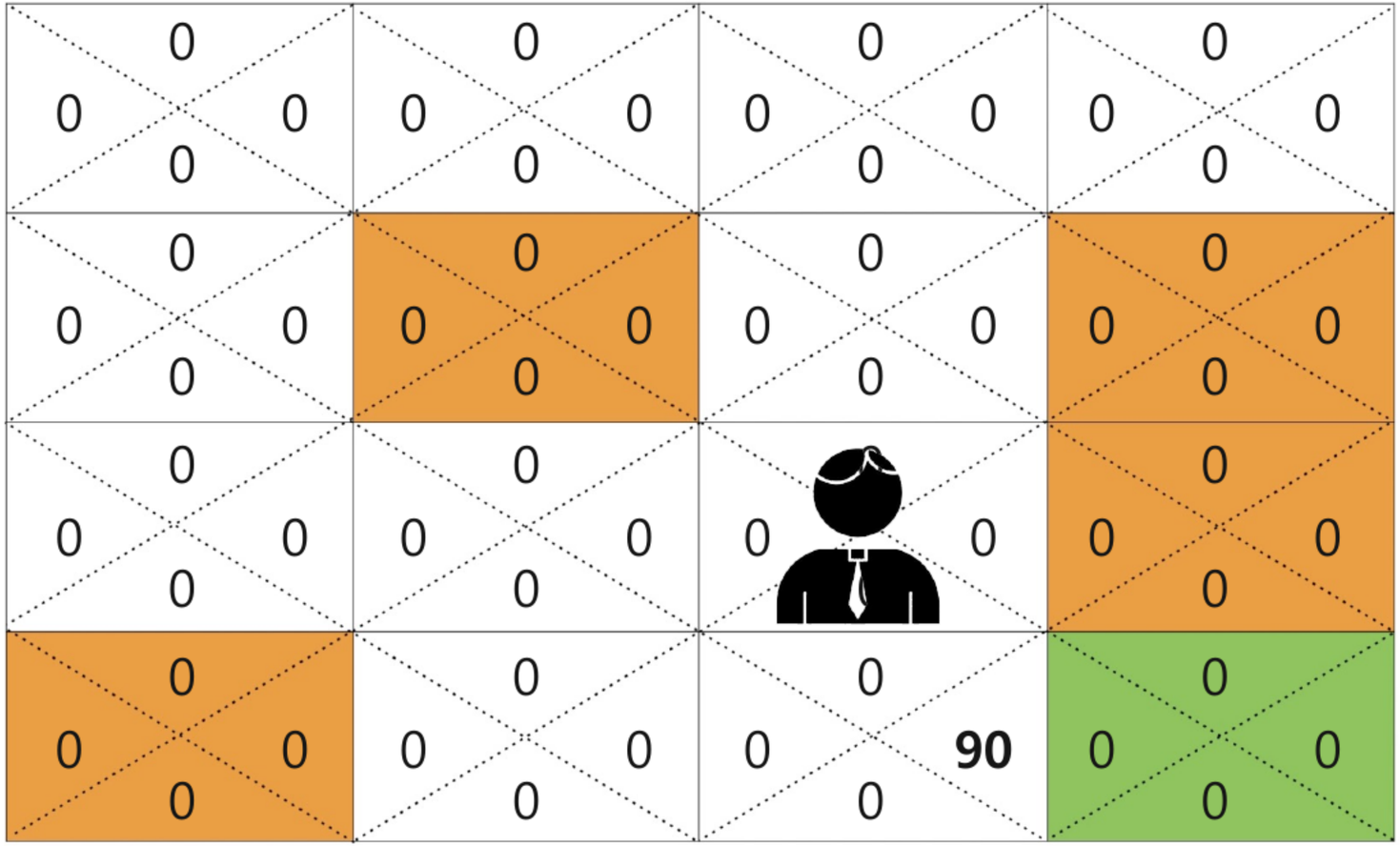
© Hackingcamp. All Rights Reserved

POC SECURITY

Q-Learning


0 0 0 0
0 0 0 0
0 0 0 0

Q-Learning



γ(disc.) = 0.9

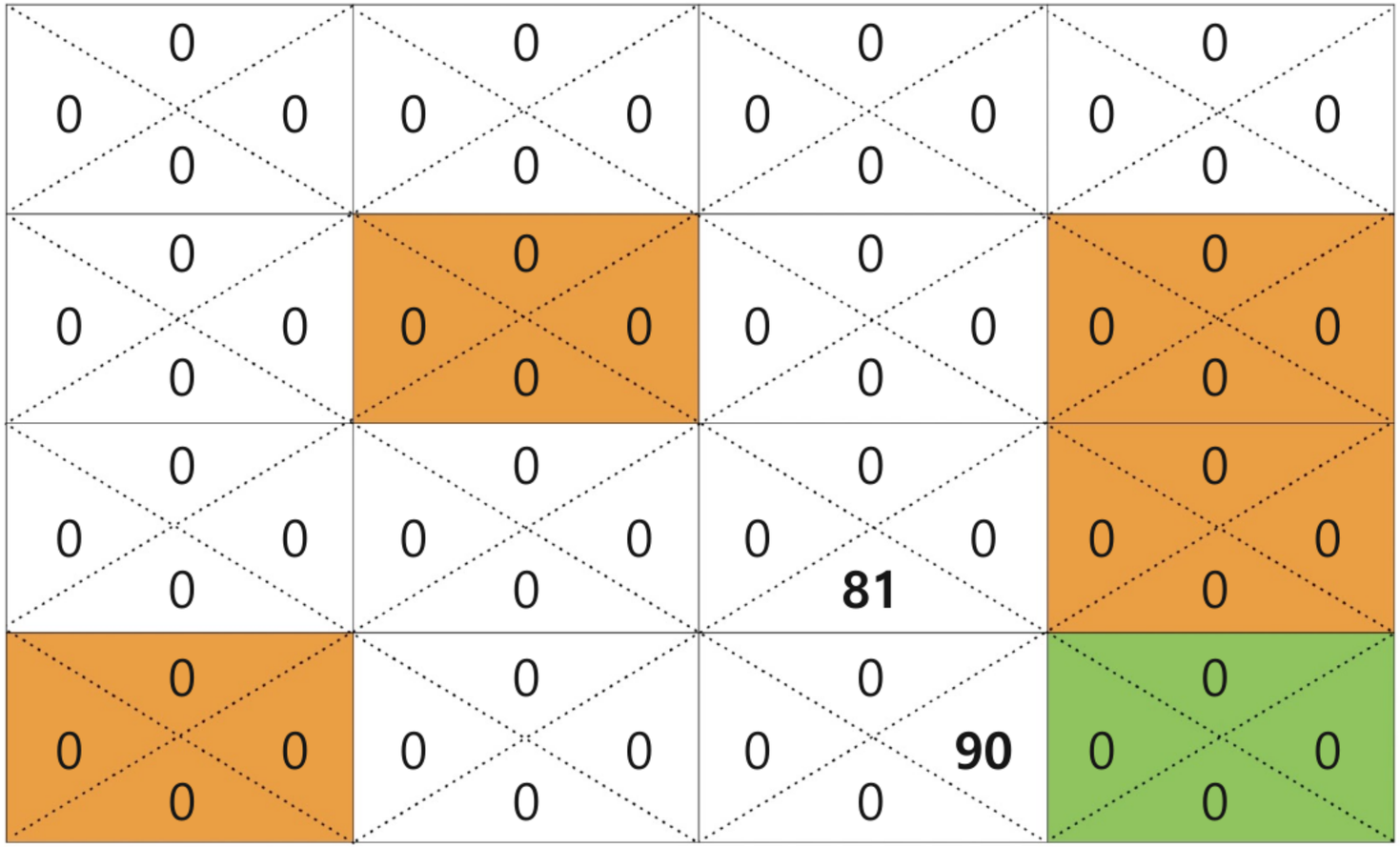
Q(10, Down)
= r + γ max(Q(s_{14}, a))

Q(10, Down)
= 0 + 0.9*90
= 81

© Hackingcamp. All Rights Reserved

POC SECURITY

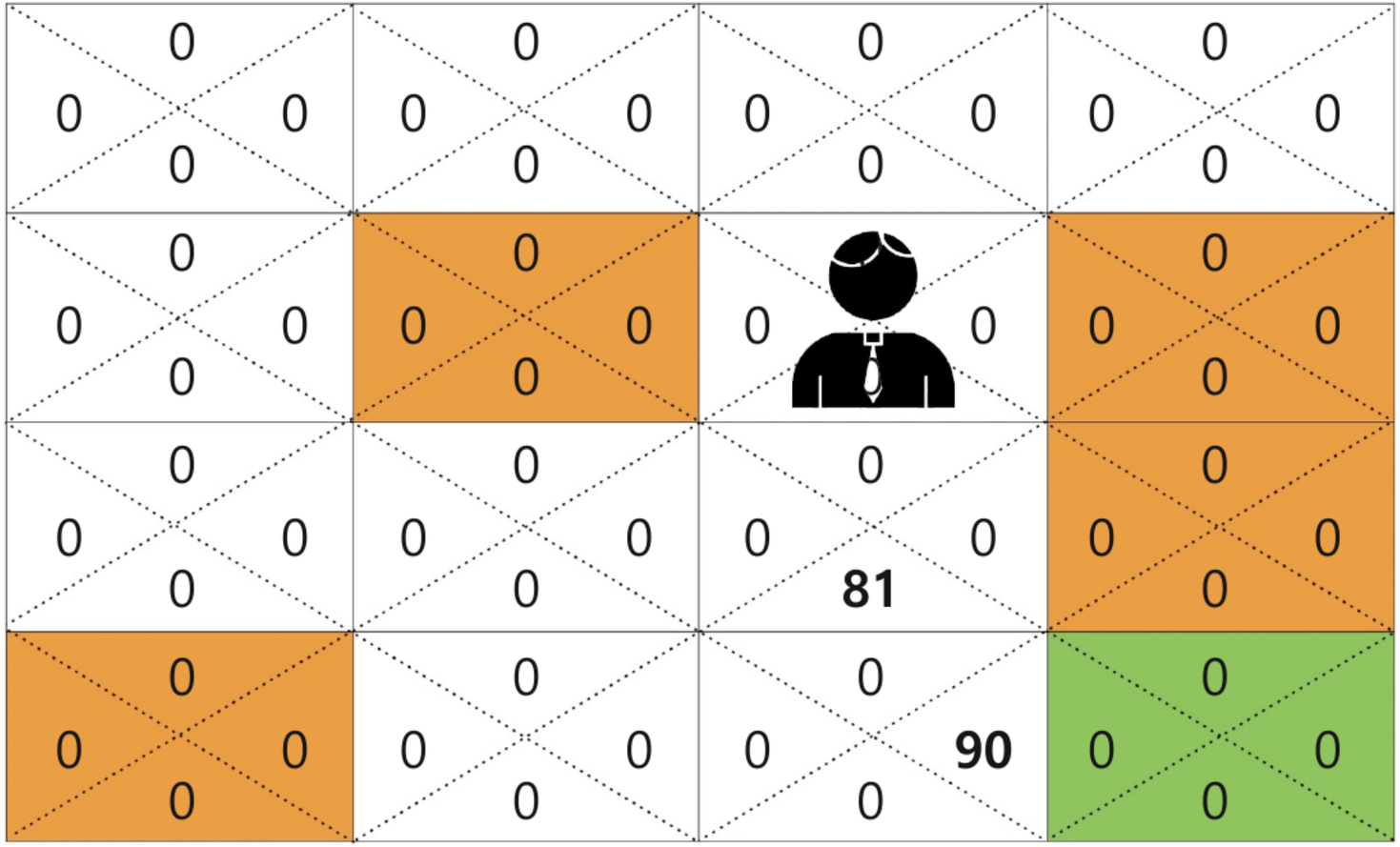
Q-Learning



© Hackingcamp. All Rights Reserved

POC SECURITY

Q-Learning



γ(disc.) = 0.9

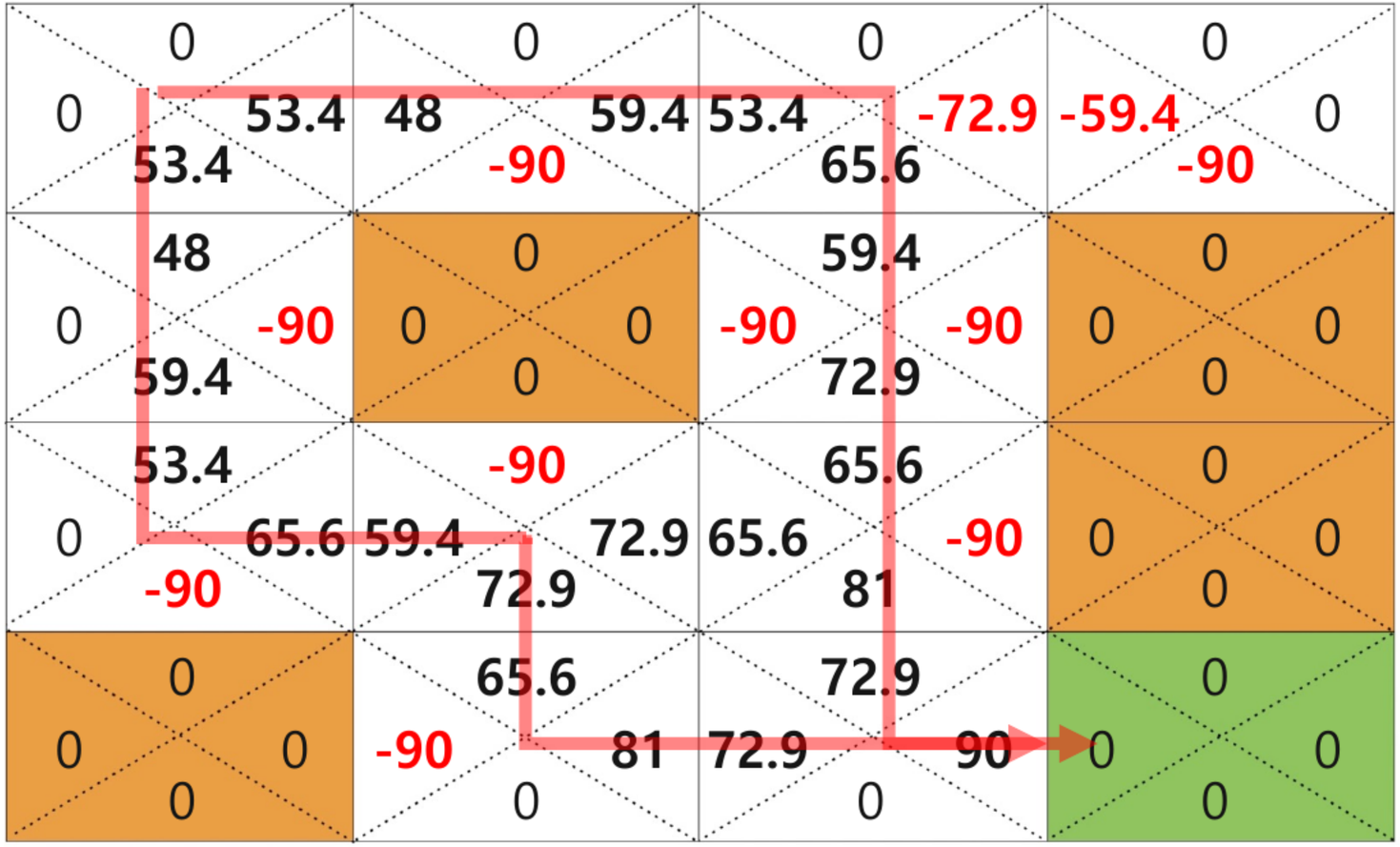
Q(10, Down)
= r + γ max(Q(s_{10}, a))

Q(10, Down)
= 0 + 0.9*81
= 72.9

© Hackingcamp. All Rights Reserved

POC SECURITY

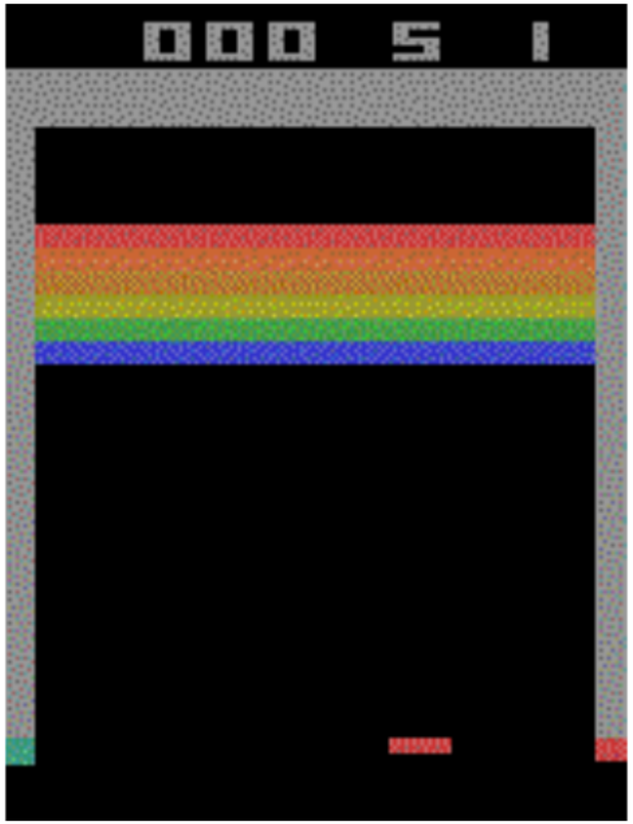
Q-Learning

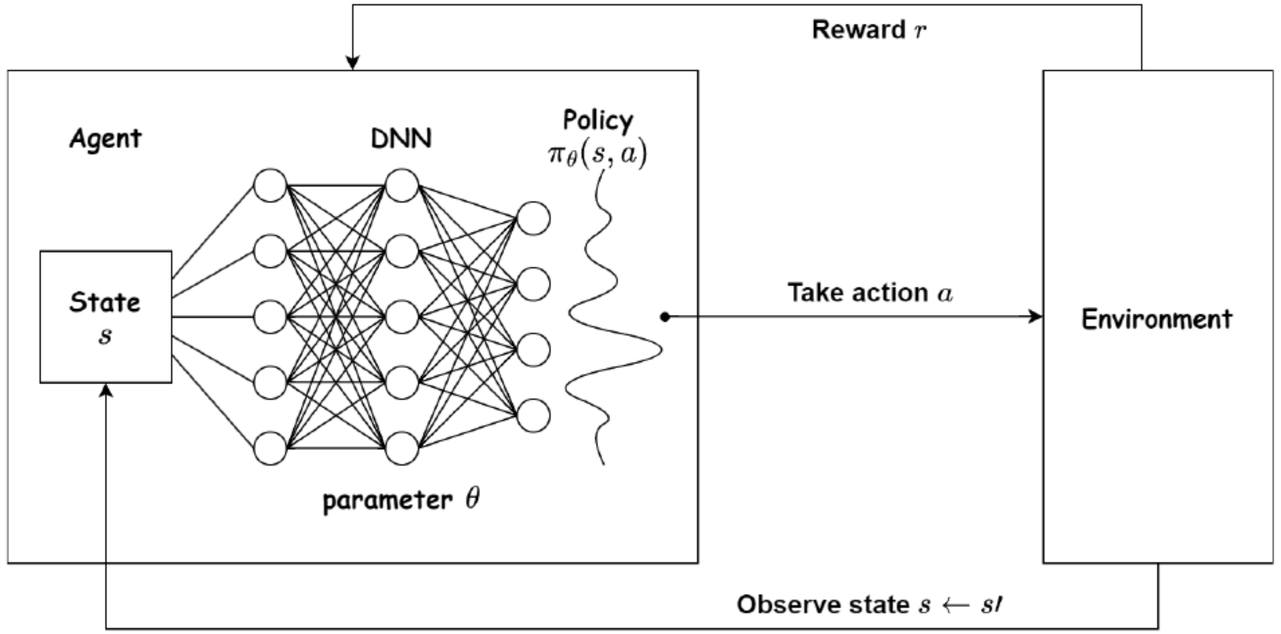


© Hackingcamp. All Rights Reserved

POC SECURITY

Q-Network

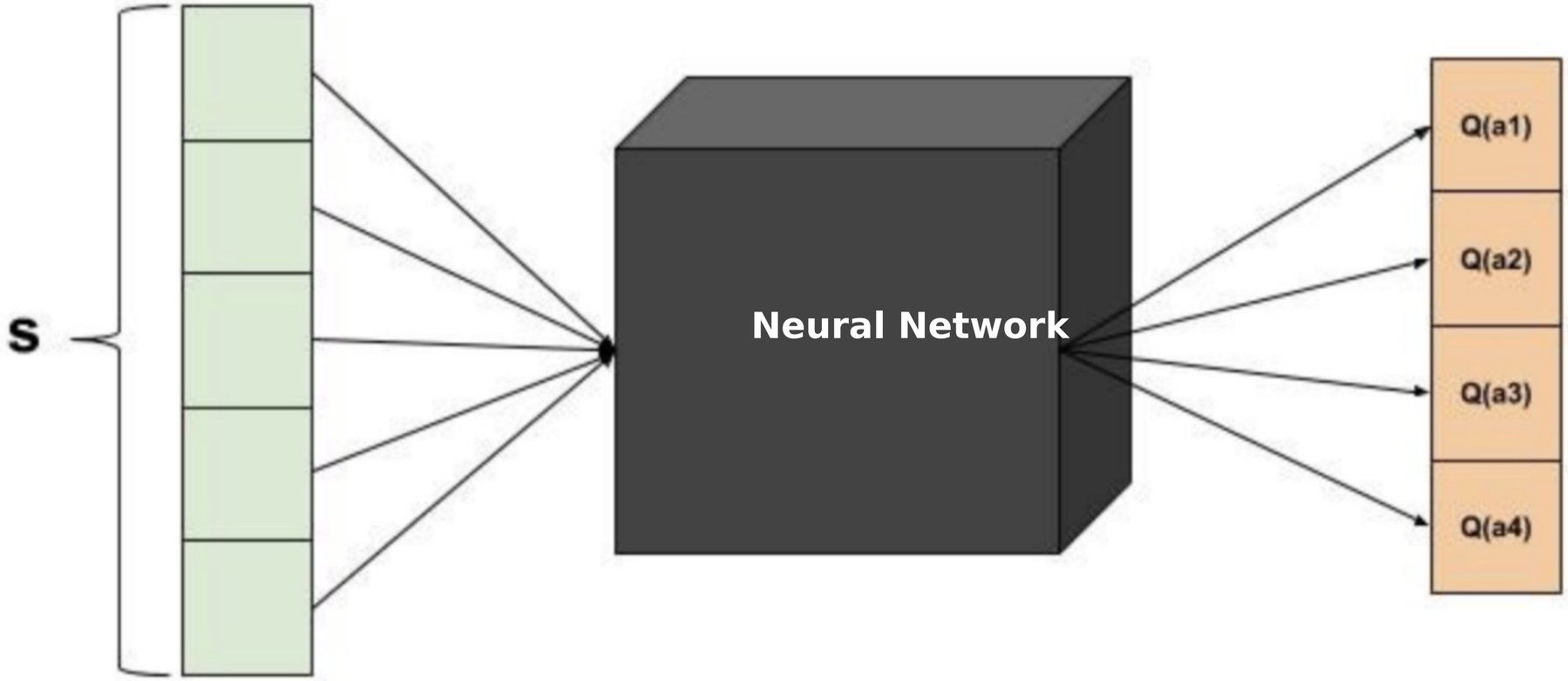




© Hackingcamp. All Rights Reserved

POC SECURITY

Q-Network



© Hackingcamp. All Rights Reserved

Reinforcement Learning for Web Hacking



Model web hacking as a reinforcement learning problem

© Hackingcamp. All Rights Reserved

POC SECURITY

Reinforcement Learning for Web Hacking



Goal, State, Action, Reward, Termination

© Hackingcamp. All Rights Reserved

POC SECURITY

Reinforcement Learning for Web Hacking



The Agent Web Model

Modelling web hacking for reinforcement learning

László Erdődi · Fabio Massimo Zennaro

© Hackingcamp. All Rights Reserved

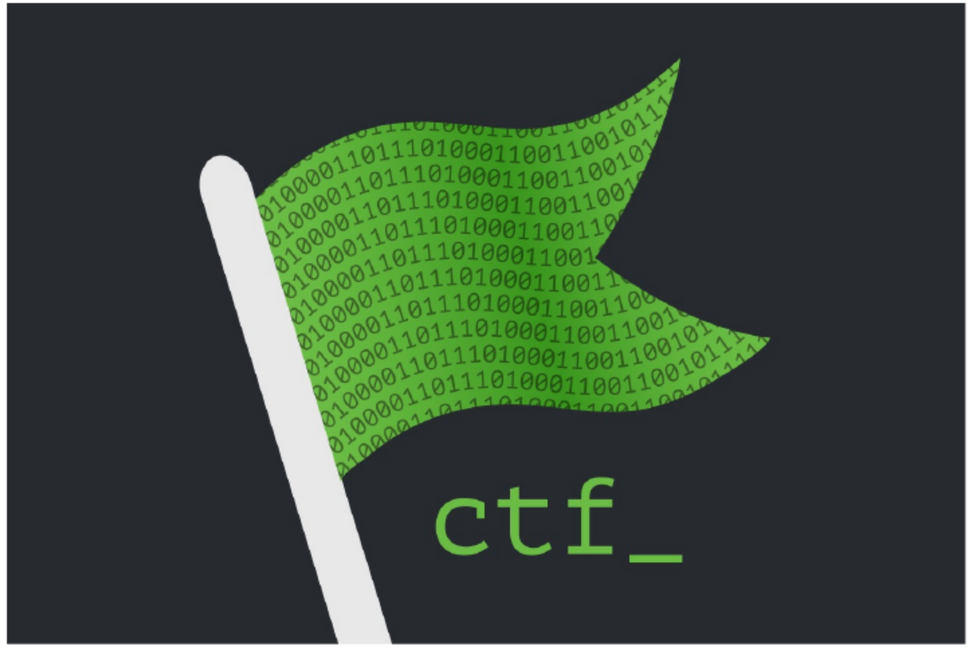
Libraries Used

OpenAI Gym provides tools for developing and testing reinforcement learning algorithms. Its environments share a common interface for evaluation and development.



© Hackingcamp. All Rights Reserved

Reinforcement Learning for Web Hacking

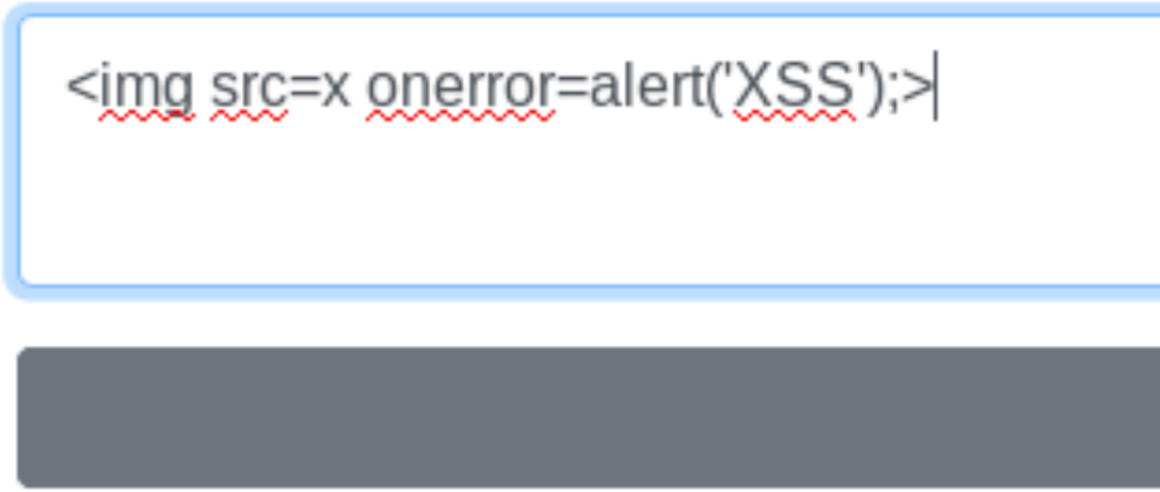


© Hackingcamp. All Rights Reserved

Purpose

- **Detect XSS (Cross-Site Scripting)**

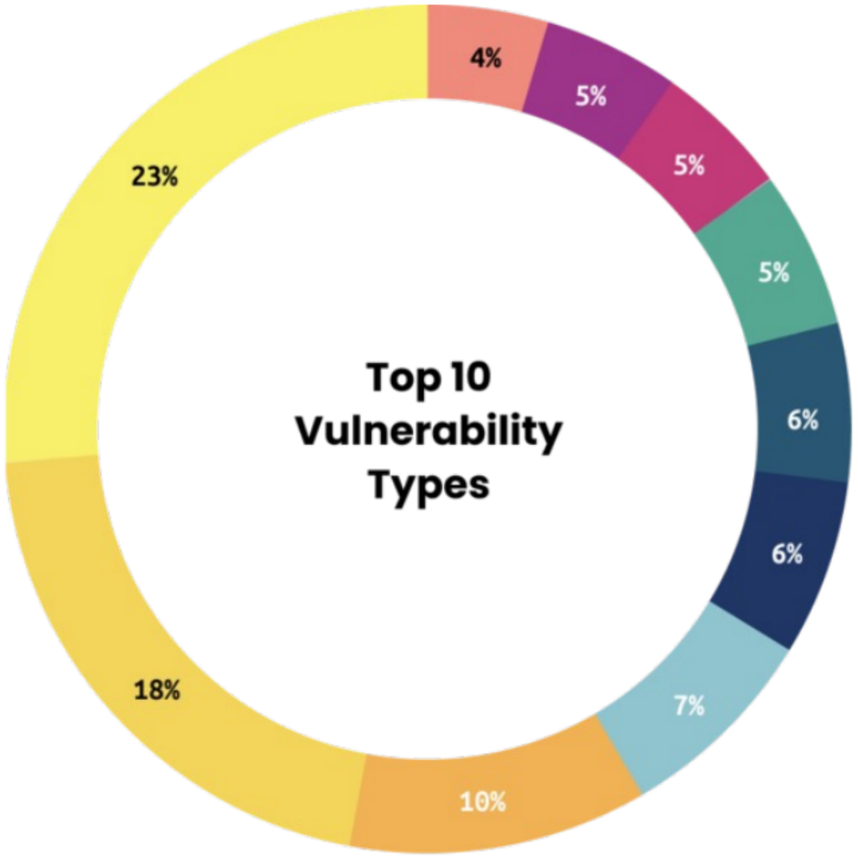
- **Detect SQL Injection**



© Hackingcamp. All Rights Reserved

POC SECURITY

Top Ten Vulnerabilities - Hackerone

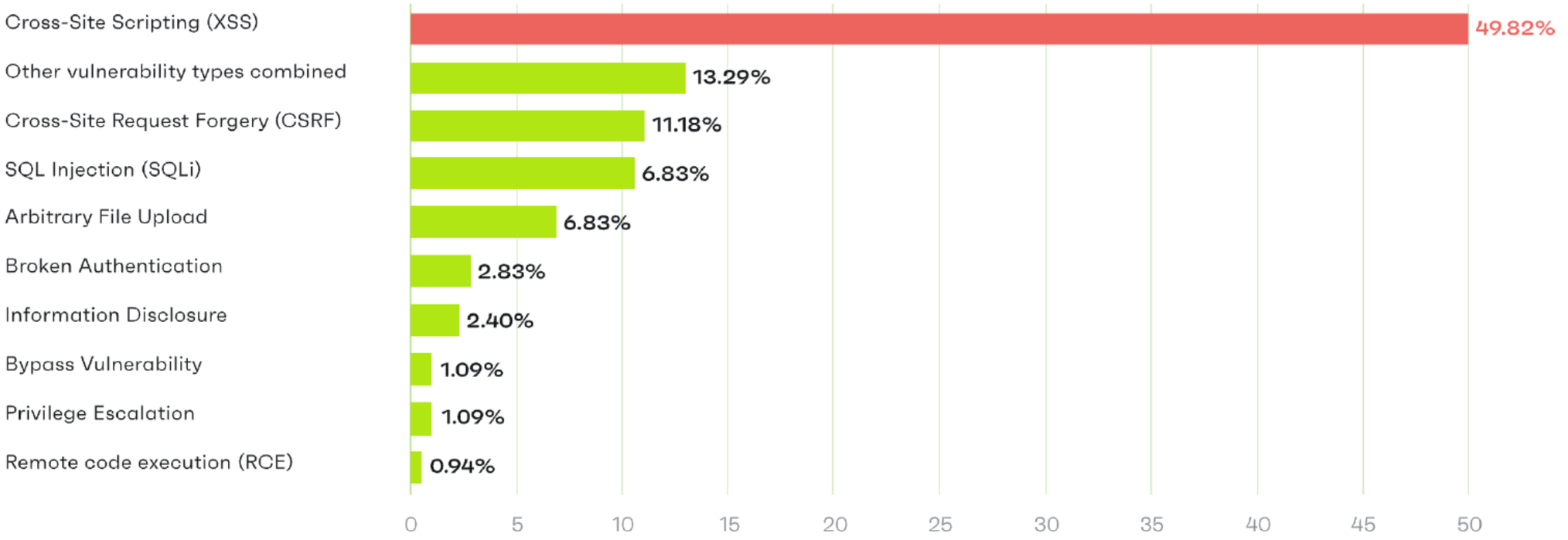


- XXS
- INFORMATION DISCLOSURE
- IMPROPER ACCESS CONTROL - GENERIC
- IMPROPER AUTHENTICATION - GENERIC
- VIOLATION OF SECURE DESIGN PRINCIPLES
- OPEN REDIRECT
- BUSINESS LOGIC ERRORS
- INSECURE DIRECT OBJECT REFERENCE (IDOR)
- PRIVILEGE ESCALATION
- CROSS-SITE REQUEST FORGERY (CSRF)

© Hackingcamp. All Rights Reserved

POC SECURITY

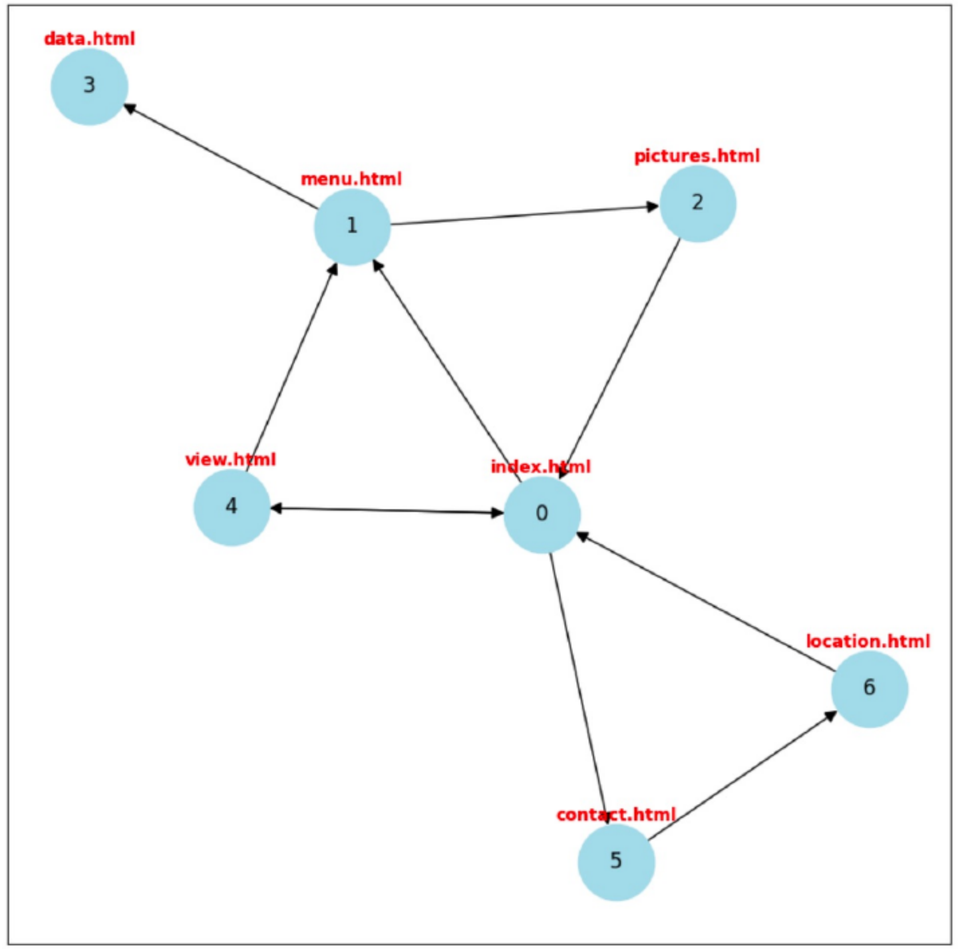
Top Ten Vulnerabilities - Patchstack



© Hackingcamp. All Rights Reserved

POC SECURITY

State



What information helps us find vulnerabilities?

- **- Available pages**
- **Parameters on each page**
- **Page URLs**

© Hackingcamp. All Rights Reserved

State

[1, 0, 0, 0, 0, 0, 0, ... 0]

- 1 : Found

- 0 : Not Found

© Hackingcamp. All Rights Reserved

Action

[CMD_Action, Target_Page]

- 0 (None) - 1~
- 1 (Read)
- 2 (XSS_Attack)
- 3 (SQLI_Attack)

© Hackingcamp. All Rights Reserved

Code



Define the observation space (state)

```
self.observation_space = spaces.MultiBinary(self.n_files)
```

Define the action space

```
self.action_space = spaces.MultiDiscrete([4,self.n_files])
```

© Hackingcamp. All Rights Reserved

Reward

- Successful attack (+100)

- Discover a new page (+5)

- Other actions (-1)

- Target a nonexistent page (-5)

© Hackingcamp. All Rights Reserved

Termination Conditions



- Successful attack

- After N seconds

© Hackingcamp. All Rights Reserved

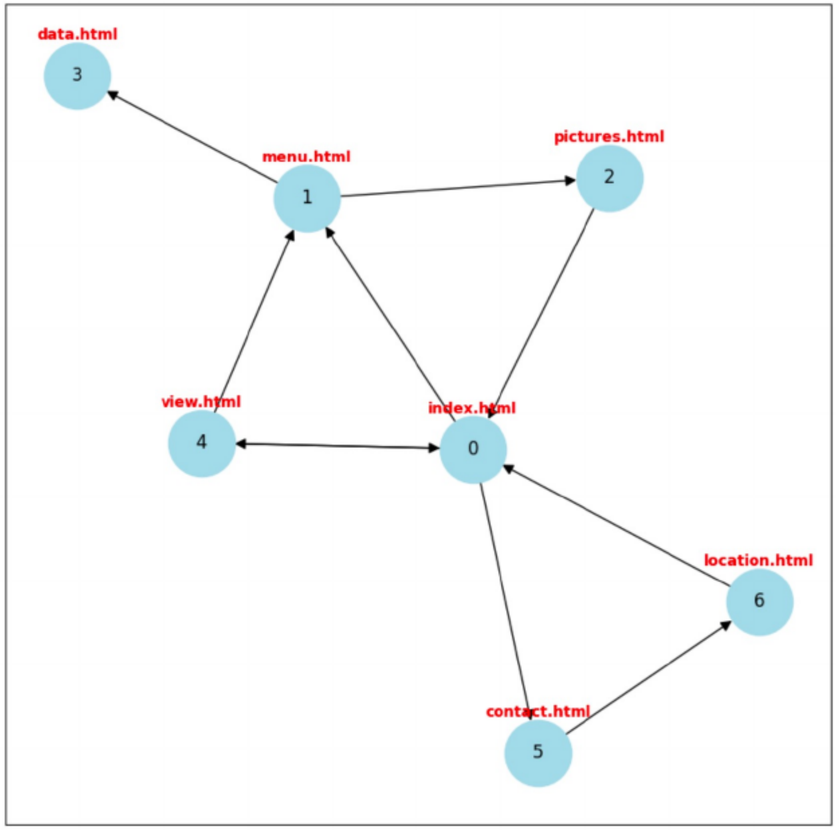


Virtual Web Server

```
# XSS Attack
elif(command==2):
    if(targetfile==self.flag and self.vul_type == 1):
      self.done = True
      return self.state,100,self.done,{'msg':'XSS_Attack Success'}
    else:
      return self.state,-5, self.done,{'msg':'XSS_Attack Fail'}

# SQLi Attack
elif(command==3):
    if(targetfile==self.flag and self.vul_type == 2):
        self.done = True
        return self.state,100,self.done,{'msg':'SQLI_Attack Success'}
    else:
        return self.state,-1,self.done,{'msg':'SQLi_Attack Fail'}

else:
    return self.state,-1,self.done,{'msg':'Wrong command'}
```



© Hackingcamp. All Rights Reserved

POC SECURITY

Code

Reset function

```
def reset(self):
    self.flag = np.random.randint(self.n_files)
    self.state = np.zeros(self.n_files,dtype=np.bool)
    self.vul_type = np.random.randint(2)
    self.state[0] = 1
    self.done = False
    return self.state
```

Called after an episode ends to reset
the environment

Step function

```
def step(self, action):
    return self.webserver(action)
```

Returns the reward, state, and done flag
after an action in the environment

© Hackingcamp. All Rights Reserved

Training the Virtual Web Server




```
gym_env = AWM()

env = DummyVecEnv([lambda: gym_env])
modelPPO = PPO("MlpPolicy", env, verbose=1, tensorboard_log="./logs/")

modelPPO.learn(total_timesteps=100000)
modelPPO.save("PPO_Agent")

del modelPPO
```

© Hackingcamp. All Rights Reserved

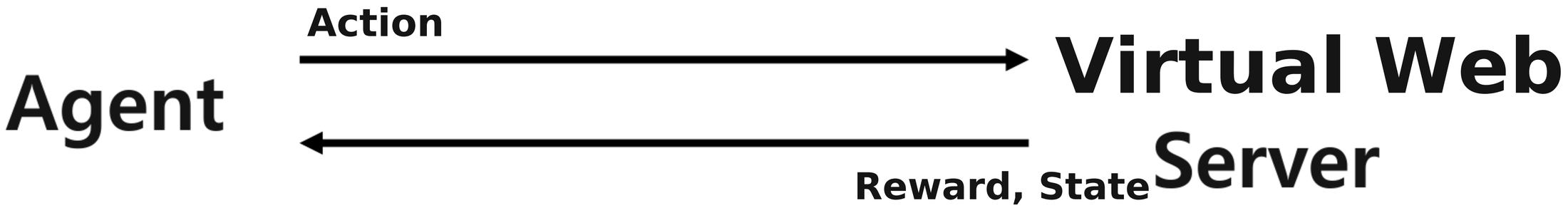
Training the Virtual Web Server




```
================================================================================
Action : SQLI_Attack
Target Page 2
State [ True  True False  True False]
Total Reward -65
================================================================================
Action : SQLI_Attack
Target Page 0
State [ True  True False  True False]
Total Reward -66
================================================================================
Action : SQLI_Attack
Target Page 4
State [ True  True False  True False]
Total Reward -71
================================================================================
Action : None
Target Page 4
State [ True  True False  True False]
Total Reward -76
================================================================================
Action : XSS_Attack
Target Page 1
State [ True  True False  True False]
Total Reward 24
```

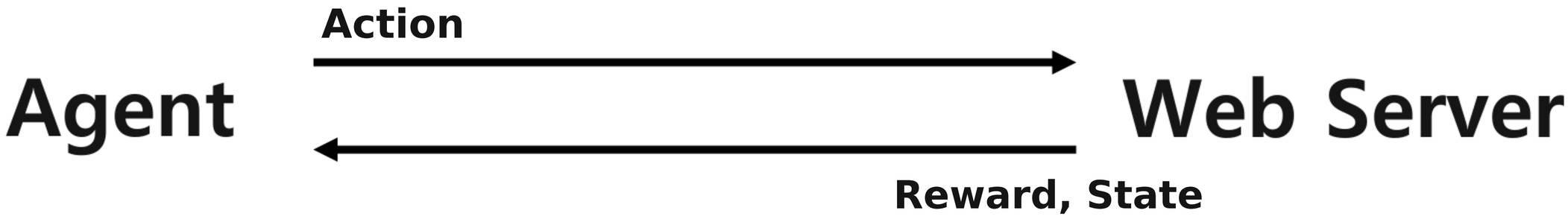
© Hackingcamp. All Rights Reserved

How It Works



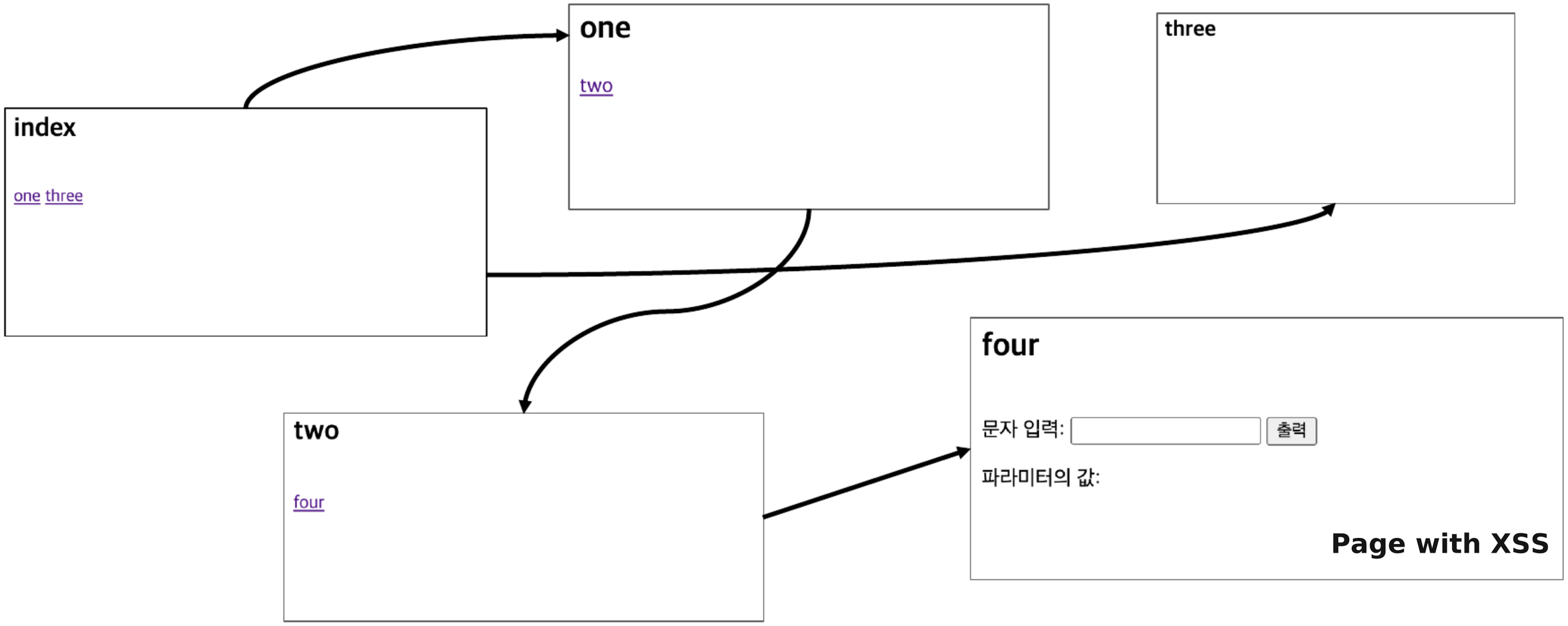
© Hackingcamp. All Rights Reserved

How It Works



© Hackingcamp. All Rights Reserved

Web Page Design



© Hackingcamp. All Rights Reserved

POC SECURITY

Selenium - Read




```python
def crawling(url, cookie=None):
    driver.get(url)
    if cookie != None:
        driver.add_cookie(cookie)
    time.sleep(1)
    soup = BeautifulSoup(driver.page_source)
    return soup
```

© Hackingcamp. All Rights Reserved

Selenium - Read

```python
def find_sub_page(now, text):
    sub_page = []

    for link in text.find_all('a'):
        href = link.get('href')

        if href == None or len(href) == 0 or href[0] == '#': continue # url이 #이거나 없으면 패스
        if urlparse(href).scheme != 'http' and urlparse(href).scheme != 'https' and urlparse(href).scheme != '': continue

        href = pre_href(now, href) # 절대 경로, 상대 경로 모두 도메인 붙여서 변경

        if urlparse(href).netloc != attack_domain: continue # 다른 도메인이면 패스
        if attack_path != '': # 만약 경로 스코프가 존재한다면 검사
            if attack_path not in urlparse(href).path: continue

        sub_page.append(href)

    return sub_page
```

© Hackingcamp. All Rights Reserved

Selenium - Attack




```python
def attack(data, pl, num, cookie):
    pl = pl.replace('{mes}', str(num)).strip() # 페이로드 완성
    get_payload = make_payload(data[1], pl)

    result = [f'alert({num})', data[0] + get_payload, []]

    url = data[0] + get_payload # 공격 url 생성
    try:
        crawling(url, cookie)
    except:
        print(f"error with {url}")
        result.append('')
        return result

    try:
        alert = Alert(driver)
        alert_txt = alert.text
        if ord('0') <= ord(alert_txt) and ord(alert_txt) <= ord(str(num)):
            print("Vulnerability Found :", url)
            result.append(alert_txt)
        while True:
            try:
                alert.dismiss()
            except:
                break
    except:
        result.append('')

    return result
```

© Hackingcamp. All Rights Reserved

Results

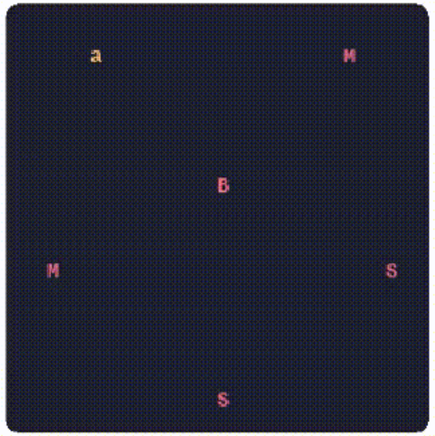
```
(venv) ✘ Otwooo ~/Documents/Project/AI_Web_Fuzzer  main ± python -u "/Users/baesonghyeon/Documents/Project/AI_Web_Fuzzer/realword_env.py"
Read.. http://localhost:8888/
XSS Attack.. http://localhost:8888/one.php
Read.. http://localhost:8888/one.php
XSS Attack.. http://localhost:8888/
XSS Attack.. http://localhost:8888/three.php
Read.. http://localhost:8888/two.php
XSS Attack.. http://localhost:8888/four.php
================================================================================
Vulnerability Found :  "http://localhost:8888/four.php?text=<script>alert(1)</script>" !!!!
Step : 18
================================================================================
```

© Hackingcamp. All Rights Reserved

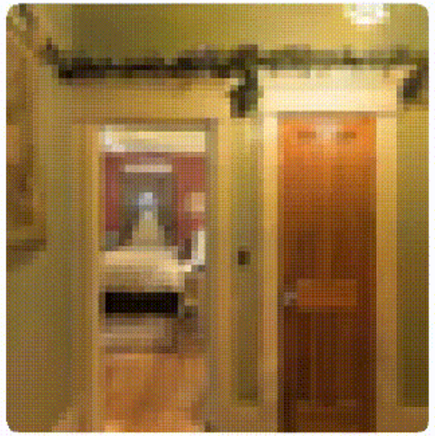
Future Work



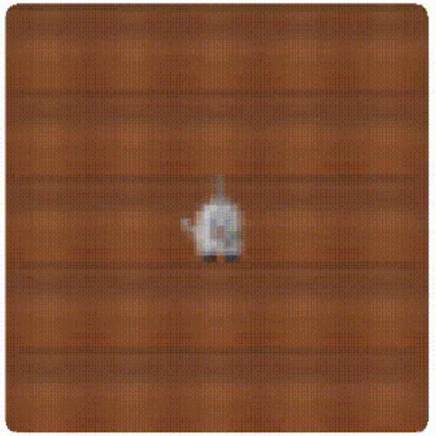
grasp



the



Walk



https://dynalang.github.io/

© Hackingcamp. All Rights Reserved

POC SECURITY

Reference

[1] Machine Learning for Everyone - Reinforcement Learning

[2] The Agent Web Model -- Modelling web hacking for reinforcement learning

[3] Deep Reinforcement Learning for Cyber Security

© Hackingcamp. All Rights Reserved

Quiz 1

Q. Which algorithm should we use to build an AI that acts like a human?

1. Supervised 2. Unsupervised 3. Reinforcement

© Hackingcamp. All Rights Reserved

Quiz 1

Q. Which algorithm should we use to build an AI that acts like a human?

1. Supervised **2. Unsupervised** **3. Reinforcement**

© Hackingcamp. All Rights Reserved

Quiz 2

Q. What is my name?

© Hackingcamp. All Rights Reserved

Quiz 2



Q. What is my name?

Songhyun Bae

© Hackingcamp. All Rights Reserved





Thank you.

QnA

Songhyun Bae (Otwooo)



POC SECURITY

© Hackingcamp. All Rights Reserved

Questions Later?

Instagram: @bshyun05
Discord: otwooo

Questions



© Hackingcamp. All Rights Reserved

POC SECURITY